

Plantilla de Reporte Ejecutivo PowerPoint

Marco GQM + PRAGMATIC aplicado a los Indicadores COSO-Ciber

Kit GQM-PRAGMATIC v2025.1 — Presentación para Consejo de Administración

"Cuando el CISO presenta al Consejo con un radar y un velocímetro, habla el idioma correcto. Cuando además explica por qué esos indicadores son los que importan —y no otros— habla con autoridad. GQM es la autoridad; PRAGMATIC es la credibilidad."

Descripción General

Nombre: GQM_PRAGMATIC_Reporte_Ejecutivo.pptx

Número de diapositivas: 16 + portada + contraportada = 18 total

Duración estimada: 30–40 minutos (incluyendo Q&A ejecutivo)

Destinatarios: Consejo de Administración / Comité de Auditoría y Riesgos / Comité Ejecutivo

Estructura de Diapositivas

DIAPPOSITIVA 0 — PORTADA

Contenido:

- Logo corporativo
- Título: **"Diagnóstico GQM-Ciber: Métricas que Importan"**
- Subtítulo: *"Trazabilidad de Objetivos Nacionales a Indicadores Técnicos · Marco COSO · PRAGMATIC Quality Filter"*
- Organización · Período · Versión · Clasificación: CONFIDENCIAL

DIAPPOSITIVA 1 — EL PROBLEMA QUE RESUELVE ESTE INFORME

Título: "¿Por qué este informe es diferente a los anteriores?"

Estructura (3 columnas):

✗ SIN GQM	✓ CON GQM	✓ CON PRAGMATIC
Medimos lo que es fácil de medir	Medimos lo que responde a un objetivo real	Solo medimos lo que vale la pena medir (calidad certificada)
Métricas vanidad (alertas, parches cerrados, concienciaciones)	Trazabilidad desde NIS2/ENS/DORA hasta el dato técnico concreto	9 criterios de calidad: Predictivo, Relevante, Oportuno, etc.
El Consejo pregunta "¿y esto qué significa?"	El Consejo entiende por qué se mide lo que se mide	El Consejo confía en que el número es real y accionable

Nota del orador: "Llevamos años presentando cuadros de mando que no generaban decisiones. GQM y PRAGMATIC son los dos filtros que garantizan que lo que presentamos hoy merece la atención del Consejo."

DIAPPOSITIVA 2 — ARQUITECTURA GQM: DE LO NACIONAL A LO TÉCNICO

Título: "La cadena de trazabilidad: del mandato político al dato del SIEM"

Contenido visual — diagrama de flujo vertical:

NIVEL 0 — OBJETIVOS NACIONALES Y REGULATORIOS
[NIS2 · ENS · DORA · Estrategia Ciber España 2025-30]

↓

NIVEL 1 — OBJETIVOS ORGANIZACIONALES (10 00)
[00-1 a 00-10, derivados de los ON]

↓

NIVEL 2 — PREGUNTAS GQM (50 preguntas)
[Qué necesitamos saber para evaluar cada 00]

↓

NIVEL 3 — MÉTRICAS (50 métricas codificadas)
[M-GOB-01 ... M-ROI-05: el dato concreto, su fuente, su frecuencia]

Mensaje clave: "Cada número de este informe tiene su origen en una obligación regulatoria o un objetivo estratégico aprobado por este Consejo."

DIAPPOSITIVA 3 — EL FILTRO PRAGMATIC: ¿POR QUÉ SOLO 50 MÉTRICAS?

Título: "De los 500 indicadores posibles a los 50 que importan"

Contenido:

9 CRITERIOS PRAGMATIC (Brotby & Hinson, 2013)

P – Predictivo:	¿Anticipa el problema?
R – Relevante:	¿Importa al Consejo?
A – Accionable:	¿Genera una decisión?
G – Genuino:	¿Mide lo que dice medir?
M – Significativo:	¿Es interpretable sin un manual?
A – Preciso:	¿El dato es exacto?
T – Oportuno:	¿Llega a tiempo para decidir?
I – Independiente:	¿Sin conflicto de interés?
C – Rentable:	¿Vale el coste de medirlo?

PUNTUACIÓN MÁXIMA: 45 puntos por métrica

NUESTRO MÍNIMO EXIGIDO: 27 puntos (≥ 3 en todos los criterios)

RESULTADO: 50 métricas Premium o Aceptables

DIAPPOSITIVA 4 — RESULTADO DE LA EVALUACIÓN PRAGMATIC

Título: "El veredicto de calidad: nuestras métricas pasan el filtro"

Contenido visual — gráfico de barras agrupadas:

[GRÁFICO: Media de cada criterio PRAGMATIC en nuestro catálogo]

Relevante (R):	4.9/5
Significativo (M):	4.6/5
Accionable (A):	4.4/5
Genuino (G):	4.1/5
Oportuno (T):	4.1/5
Preciso (Ac):	3.8/5
Rentable (C):	3.8/5
Predictivo (P):	3.7/5
Independiente (I):	3.5/5

Línea de umbral — 3.0/5

[Nota: el criterio más débil (I = 3.5) activa controles compensatorios: auditoría independiente semestral de las métricas de mayor riesgo de sesgo]

DIAPPOSITIVA 5 — EL ÍNDICE GLOBAL DE MADUREZ (IGM)

Título: "¿Dónde estamos en el mapa de la madurez ciber?"

[GRÁFICO VELOCÍMETRO / GAUGE]

Escala 1-5 | Zonas de color | Aguja en [X.X]

1.0-1.9 CRÍTICO	→ [X organizaciones en el sector]
2.0-2.9 EMERGENTE	→ [X organizaciones en el sector]
3.0-3.9 ESTABLECIDO	→ [Aquí estamos nosotros / benchmarking]
4.0-4.5 AVANZADO	→ [X organizaciones líderes]
4.6-5.0 LÍDER	→ [X organizaciones de referencia mundial]

Tabla de apoyo:

Componente	IGM	vs. Sector	Tendencia	Observación
C-I Gobernanza	X.X	[+/-]	↑↓→	[texto]
C-II Estrategia	X.X	[+/-]	↑↓→	[texto]
C-III Desempeño	X.X	[+/-]	↑↓→	[texto]
C-IV Revisión	X.X	[+/-]	↑↓→	[texto]
C-V Reporte	X.X	[+/-]	↑↓→	[texto]
IGM Total	X.X	[+/-]	↑↓→	[nivel]

DIAPPOSITIVA 6 — GRÁFICO RADAR COSO (SPIDER CHART)

Título: "La silueta de nuestra madurez en 5 dimensiones"

[SPIDER CHART — 5 EJES]

Eje máximo: 5.0 | Mínimo: 0

Área rellena azul = IGM de la organización (actual)

Línea punteada naranja = media del sector

Línea punteada verde = objetivo aprobado (12 meses)

Los 5 ejes:

- C-I Gobernanza (peso 25%)
- C-II Estrategia (peso 20%)
- C-III Desempeño (peso 30%)
- C-IV Revisión (peso 10%)
- C-V Reporte (peso 15%)

Mensaje clave: "La mayor brecha con el sector está en [componente]. Es nuestra prioridad de mejora."

DIAPPOSITIVA 7 — LOS 14 INDICADORES DE ALERTA TEMPRANA

Título: "Los 14 semáforos que no mienten"

Grid 7×2 con cada IAT:

[SEMÁFORO] M-GOB-01 Frec. Consejo [VALOR] [SEMÁFORO] M-GOB-02 Comp. ciber Consejo [VALOR]

[SEMÁFORO] M-GOB-04 Indep. CISO [VALOR] [SEMÁFORO] M-GOB-05 Apetito € [VALOR]

[SEMÁFORO] M-EST-01 Int. estratégica [V] [SEMÁFORO] M-DET-01 MTTD [VALOR] h

[SEMÁFORO] M-DET-03 Tend. MTTD [VALOR]% [SEMÁFORO] M-VUL-01 TTP crítico [V] días

[SEMÁFORO] M-VUL-02 CVE >30d [VALOR]% [SEMÁFORO] M-IAM-01 MFA priv. [VALOR]%

[SEMÁFORO] M-IAM-02 MFA remoto [VALOR]% [SEMÁFORO] M-RES-01 RTO [VALOR]%

[SEMÁFORO] M-SCM-01 Prov. eval. [VALOR]% [SEMÁFORO] M-RPT-04 Escalado [0-3]

● Crítico | ● Mejorable | ● Adecuado

DIAPPOSITIVA 8 — MÉTRICAS OPERATIVAS CLAVE (MTTD, MTTR, TTP, MFA)

Título: "El pulso operativo en 8 tarjetas"

[8 TARJETAS KPI en formato 4x2]

[MTTD]	[MTTR]	[TTP Crit]	[MFA Priv]
[valor]	[valor]	[valor]	[valor]
[color]	[color]	[color]	[color]
ref: Xh	ref: Xh	ref: Xd	ref: 100%

[IAM Rev]	[Dwell T]	[RTO ratio]	[ROSI]
[valor]	[valor]	[valor]	[valor]
[color]	[color]	[color]	[color]
ref: 30d	ref: <7d	ref: <105%	ref: >0%

DIAPPOSITIVA 9 — CUANTIFICACIÓN FINANCIERA DEL RIESGO

Título: "El ciberriesgo en euros: lo que está en juego"

Contenido:

TOP 5 ESCENARIOS DE RIESGO (por ALE)

Escenario	ALE(€/a)	Prob/año	Reducción
1. [Ransomware ERP]	X.X M€	X.X%/año	-XX% con [control]
2. [Brecha datos cust.]	X.X M€	X.X%/año	-XX%
3. [Ataque supply chain]	X.X M€	X.X%/año	-XX%
4. [BEC / fraude CEO]	X.X M€	X.X%/año	-XX%
5. [DDoS serv. crítico]	X.X M€	X.X%/año	-XX%
ALE TOTAL SIN PROGRAMA	XX.X M€		
ALE TOTAL CON PROGRAMA	XX.X M€	-XX%	

Referencia: Coste medio de brecha en el sector [X M€]
(Fuente: IBM Cost of Data Breach 2025 + ajuste sectorial España)

DIAPPOSITIVA 10 — ROSI: EL LENGUAJE DEL CFO

Título: "¿Cuánto vale nuestra inversión en ciberseguridad?"

[BARRAS HORIZONTALES — ROSI por control, ordenado descendente]

MFA Universal	[ROSI: XXX%]	
EDR/XDR	[ROSI: XXX%]	
Backup inmutable	[ROSI: XXX%]	
Gestión vulns.	[ROSI: XXX%]	
Zero Trust parcial	[ROSI: XXX%]	
[Control N]	[ROSI: XXX%]	
...		

ROSI MEDIO DEL PROGRAMA: [XX]%
PAYBACK PERIOD MEDIO: [XX] meses
RIESGO REDUCIDO/AÑO: [X.X] M€

Línea de referencia: ROSI = 0% (límite de rentabilidad)

DIAPPOSITIVA 11 — RIESGOS EMERGENTES: IA Y COMPUTACIÓN CUÁNTICA

Título: "El horizonte que ya está llegando"

 IA ADVERSARIAL	 AMENAZA CUÁNTICA
M-EMG-03: % reglas SOC para ataques IA Estado: [COLOR/VALOR]	M-EMG-01: Inventario PQC [X%] sistemas mapeados Estado: [COLOR]
TtE con IA: < 6 horas (CISA 2025) Nuestro MTTD: [X] horas	M-EMG-02: Hoja de ruta PQC aprobada: [SÍ/NO] Horizonte: 2026-2030
M-EMG-04: % sistemas IA con eval. riesgo: [X%] [COLOR]	M-EMG-05: % datos SNDL evaluados: [X%] [COLOR]

DIAPPOSITIVA 12 — ESTADO REGULATORIO: NIS2 / DORA / ENS

Título: "El marcador de cumplimiento normativo"

[SEMÁFOROS DE CUMPLIMIENTO POR MARCO]

NIS2 (Dir. 2022/2555)
Estado: [COLOR] XX%

DORA (Reg. 2022/2554)
Estado: [COLOR] XX% / N/A

Brechas principales:
· Art. 20 – Gobernanza [X]
· Art. 21(2j) – IAM [X]
· Art. 23 – Notificación [X]

Brechas principales:
· Art. 5 – Govern. TIC [X]
· Art. 11 – Resiliencia [X]
· Art. 28 – Terceros [X]

ENS (RD 311/2022)
Estado: [COLOR] XX% / N/A

EU AI Act (2024/1689)
Estado: [COLOR] / Aplica desde
agosto 2026

DIAPPOSITIVA 13 — HALLAZGOS PRAGMATIC SOBRE LA CALIDAD DE LAS MÉTRICAS

Título: "Lo que sí sabemos y lo que debemos mejorar en cómo medimos"

Contenido en 2 columnas:

FORTALEZAS (criterios PRAGMATIC > 4.0)

✓ Relevancia (R=4.9):
Todas las métricas responden a
objetivos del Consejo y mandatos
regulatorios.

✓ Accionabilidad (A=4.4):
La mayoría genera una decisión o
acción concreta cuando cambia.

✓ Significatividad (M=4.6):
El Consejo puede interpretar los
datos gracias a benchmarks
contextuales (IBM, ENISA, CIS).

ÁREAS DE MEJORA (criterios < 3.8)

⚠ Independencia (I=3.5):
Riesgo de sesgo en métricas
generadas por el mismo equipo
que controla los procesos medidos.
ACCIÓN: Auditoría independiente
semestral de MTTD, MFA, IAM.

⚠ Precisión en cuantif. FAIR (Ac=3.4):
Los modelos ALE/FAIR producen
estimaciones, no certezas.
ACCIÓN: Presentar intervalos de
confianza junto a valores puntuales.

⚠ Oportunidad en EMG (T=3.6):
Las métricas de riesgos emergentes
requieren auditorías periódicas
que aún no están automatizadas.

DIAPPOSITIVA 14 — PLAN DE MEJORA PRIORIZADO (Roadmap)

Título: "De las métricas a las acciones: el roadmap de los próximos 24 meses"

0-90 DÍAS (IATs críticos – impacto inmediato)

1. [Acción sobre IAT crítico 1] → CISO → [Presupuesto] → [KPI]
2. [Acción sobre IAT crítico 2] → CTO → [Presupuesto] → [KPI]
3. [Auditoría independiente métricas de mayor riesgo de sesgo]

3-12 MESES (mejora estructural de indicadores en amarillo)

4. [Automatización del dashboard GQM-Ciber en la plataforma GRC]
5. [Implementar intervalos de confianza en cuantificación FAIR]
6. [Iniciar inventario criptográfico para hoja de ruta PQC]

12-24 MESES (transformación estratégica)

7. [IGM objetivo: X.X – revisión anual del kit GQM-Ciber]
8. [Integración del cuadro de mando GQM en informes del Consejo]

DIAPPOSITIVA 15 — DECISIONES SOLICITADAS AL CONSEJO

Título: "Cuatro decisiones que transforman el programa"

1. APROBACIÓN del presupuesto adicional de [X€] para cerrar los [N] IATs críticos
Impacto: Reducción estimada del ALE en [X M€/año] | Plazo: 90 días | Resp.: CISO + CFO
2. MANDATO para auditorías independientes semestrales de métricas de riesgo de sesgo
Impacto: Aumento del criterio PRAGMATIC-I de 3.5 a 4.5 | Plazo: 30 días | Resp.: AI
3. INCLUSIÓN del reporte GQM-Ciber (diapositivas 5, 6, 7) como punto fijo de agenda trimestral
Impacto: Cumplimiento COSO CGF 2026 P-8 + NIS2 Art. 20 | Plazo: Próxima sesión | Resp.: Secretaría
4. APROBACIÓN de la hoja de ruta PQC (migración a criptografía post-cuántica 2025-2030)
Impacto: Mitigación del riesgo SNDL sobre datos con vida útil >10 años | Plazo: 6 meses | Resp.: CISO + CTO

DIAPPOSITIVA 16 — PRÓXIMOS PASOS

Contenido:

- Tabla de compromisos: Acción | Responsable | Fecha | Métrica de éxito
- Próxima revisión del IGM: [fecha]
- Próxima evaluación PRAGMATIC del catálogo de métricas: [fecha]
- Documentación de respaldo:
 - Marco GQM completo (Documento a)
 - Matriz PRAGMATIC (Documento b)
 - Mapeo normativo (Documento d)
 - Plantilla Excel IGM/ROSI (Documento e — para validación del CFO)

DIAPPOSITIVA 17 — CONTRAPORTADA

- "Preguntas, debate y compromisos"
- Clasificación: CONFIDENCIAL
- Pie: "Kit GQM-PRAGMATIC v2025.1 | [Fecha] | [Organización]"

Principios de Diseño Específicos para el Marco GQM+PRAGMATIC

1. Nombrar el método: El Consejo debe saber que las métricas pasaron el filtro PRAGMATIC. No es marketing — es credibilidad metodológica.
2. Mostrar la trazabilidad en dos diapositivas máximo: El diagrama GQM completo (diapositiva 2) y la tabla de cobertura normativa (diapositiva 12) son suficientes.
3. Los criterios PRAGMATIC se presentan una sola vez (diapositivas 3–4) y se referencian en adelante solo cuando hay un hallazgo relevante (como el Independiente = 3.5).
4. No sobrecargar con los 50 indicadores: El Consejo ve el resumen (diapositivas 5–8); los 50 indicadores van en el Anexo o en la plantilla Excel.

Plantilla PPT GQM+PRAGMATIC — Kit GQM-PRAGMATIC v2025.1 | Abril 2026